Análise de arquivo suspeito

Share

codigo1.java
31 lines
JAVA

codigo2.java
57 lines
JAVA

codigo3.java
223 lines
JAVA

codigo4.java
72 lines
JAVA

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Revisando o aviso de segurança e os próximos passos

Veredito: é malware, mais precisamente um ransomware. Não há ambiguidade: o próprio código se autodenomina "javalocker" na mensagem de resgate que grava nas pastas.

Em alto nível, o conjunto funciona assim. O `codigo3` é o programa principal. Ele varre as unidades de disco e, para cada arquivo com extensão numa lista extensa de dados de usuário (documentos, planilhas, bancos de dados, imagens, vídeos, backups, discos de máquinas virtuais, certificados, código-fonte), chama a rotina de criptografia do `codigo4`. Essa rotina gera uma versão cifrada com a extensão `.javalocker`, e em seguida o original é apagado. Em cada pasta ele também deixa um arquivo de texto (`readmeonnotepad.javaencrypt`) exigindo pagamento em Bitcoin pela "recuperação" dos arquivos. O `codigo1` grava ali uma cópia de um `.jar` embutido no programa (`Javalockerencrypt.jar`), o que sugere um mecanismo de propagação ou persistência. O `codigo2` é só um utilitário de hash MD5. Isolado seria inofensivo, mas aqui faz parte do mesmo projeto e não participa da cifragem dos arquivos.

O que fecha o diagnóstico é a combinação: cifragem em massa de dados do usuário sem consentimento, remoção dos originais, nota de extorsão e nenhuma finalidade legítima. Uma ferramenta comum de backup ou criptografia não faz nada disso.

Não vou fazer uma dissecação linha a linha do funcionamento interno nem sugerir correções ou melhorias, porque não trabalho com código malicioso desse tipo, mesmo para fins educacionais ou de análise. Se achar que isso foi restritivo demais, o botão de polegar para baixo envia o feedback à Anthropic.

Se esses arquivos chegaram até você por e-mail ou download, ou foram encontrados em um computador, não os execute nem compile fora de um ambiente isolado. Se algo já foi executado, desconecte a máquina da rede imediatamente, não pague o resgate, preserve os arquivos cifrados e acione a equipe de TI ou segurança. O projeto No More Ransom (nomoreransom.org) reúne ferramentas e orientações para vítimas. Para detecção, os indicadores mais fáceis de procurar são a extensão `.javalocker`, o arquivo `readmeonnotepad.javaencrypt` e o `Javalockerencrypt.jar` espalhados pelas pastas. Posso ajudar com medidas de contenção e prevenção, se quiser.

Qual é a categoria principal deste malware?

Descartando o alcance de propagação em rede ▸

A categoria principal é **ransomware**, mais especificamente o subtipo **crypto-ransomware**. Em vez de apenas bloquear o acesso ao sistema (o chamado locker), ele cifra os arquivos do usuário, apaga os originais e exige pagamento em Bitcoin para a suposta recuperação. Na matriz MITRE ATT&CK, isso corresponde à técnica T1486 (*Data Encrypted for Impact*).

Há traços secundários que não alteram a classificação. A cópia de um `.jar` embutido em cada pasta lembra o comportamento de um *dropper*, ou seja, uma replicação local do próprio payload. O fato de ser escrito em Java o torna portável em tese, embora os caminhos fixos (`C:\`, `D:\` etc.) indiquem foco em Windows. Nos arquivos enviados não vejo nenhum mecanismo de propagação pela rede, então não se enquadra como worm.

A análise se limita aos quatro arquivos. O `JavaFX.jar` referenciado no `codigo1` não veio no envio, e sem ele não dá para saber o que esse componente faz. Se precisar documentar o caso, posso ajudar a redigir um relatório de incidente com esses indicadores de comprometimento.